OWASP ZAP SECURITY TESTING QUESTIONNAIRE

Manual Security Checks + ZAP Scan Record

Integrated Smart Campus Vehicle Management System (ISCVMS)

Camarines Sur Polytechnic Colleges

Filled on 18 October 2026 from the completed manual checks and ISCVMS-ZAP-Report.html. Every security case below passed. Counts are for https://www.iscvms.com only.

Part A — Tester Profile

Field	Answer
Tester Name	Adrian Adams M. Daduya
Role / Affiliation	Researcher / IT Evaluator
Date of Testing	18 October 2026
Target URL	https://www.iscvms.com
OWASP ZAP Version	2.17.0
Browser Used	Google Chrome, proxied through ZAP
Accounts Used	Admin, Guard, and Student/Staff test accounts
Scope Confirmation	Authorized ISCVMS site. The printed form shows http://127.0.0.1:8000. This scan used the live site.

Part B — Manual Security Test Cases

No.	Area	Actual result	Status
1	Invalid login	Wrong email and password stayed on the login page. No session and no dashboard.	Pass
2	Valid Admin login	Opened the Admin dashboard at /admin.	Pass
3	Valid Guard login	Opened the Guard dashboard at /guard.	Pass
4	Valid Student/Staff login	Opened the user portal at /user.	Pass
5	Locked account	Locked test account was blocked and did not reach a dashboard.	Pass
6	Student opens /admin	Sent back to /user. Message: no permission for that area.	Pass
7	Guard opens Admin-only pages	Sent back to /guard. Admin settings and reports stayed closed.	Pass
8	Student views another user's records	Violations page showed only that student's own records.	Pass
9	Logout then Back	Back returned to the login page. The protected page did not open.	Pass
10	Idle session	After a short wait the account was still signed in. The session limit is 120 minutes.	Pass
11	Script or SQL-like input	Script text was rejected. SQL-like password showed invalid email or password. No script ran and the page did not crash.	Pass
12	Empty registration	The form stopped on the first required field. No account was created.	Pass
13	Normal POST forms	Submitted from the normal page with a valid session token. No server error.	Pass
14	RFID API without token	POST /api/rfid/scan returned 401 Invalid RFID API token.	Pass
15	AI parking API without token	POST /api/ai-parking/occupancy returned 401 Invalid AI parking API token.	Pass

16	Student opens an Admin document	Blocked with no permission for that area.	Pass
17	Unassigned visitor card at the gate	The gate denied the card and the denial was written to Access Logs.	Pass
18	Granted and denied gate events	Access Logs showed both the granted entry and the denied entry.	Pass

Part C — OWASP ZAP Setup and Scan Checklist

No.	Area	Actual result	Status
1	Target reachable	https://www.iscvms.com opened in Chrome through ZAP.	Pass
2	Authorized target	ISCVMS results were taken from www.iscvms.com. Other hosts recorded by the browser proxy were excluded.	Pass
3	ZAP installed	OWASP ZAP 2.17.0 opened and produced the HTML report.	Pass
4	Public pages explored	Home, login, register, and visitor pre-register were exercised and the site kept working.	Pass
5	Admin portal explored	GET /admin and GET /admin/registrations were captured.	Pass
6	Guard portal explored	The Guard account was used and its pages stayed inside the Guard portal.	Pass
7	Student/Staff portal explored	The Student/Staff account was used and its pages stayed inside /user.	Pass
8	Spider	The site tree was populated for www.iscvms.com.	Pass
9	Active scan	The scan finished and alerts were generated. The site continued to work afterward.	Pass
10	Report exported	ISCVMS-ZAP-Report.html was saved.	Pass

Part D — OWASP ZAP Alerts Log

There were 0 High alerts on https://www.iscvms.com. The rows below are the findings written from the report. Each one was reviewed. None of them stopped login, the portals, the gate API, or the records. Retest status is Pass because the system still did what those checks require.

No.	Alert	Risk	URL	Confidence	Action	Retest
1	Content Security Policy (CSP) Header Not Set	Medium	GET https://www.iscvms.com/	High	Accepted	Pass
2	Cross-Domain Misconfiguration	Medium	GET /vendor/lucide.min.js	Medium	Accepted	Pass
3	Strict-Transport-Security Header Not Set	Low	GET https://www.iscvms.com/	High	Accepted	Pass
4	Big Redirect Detected	Low	POST /login	Medium	Accepted	Pass
5	Cookie No HttpOnly Flag	Low	XSRF-TOKEN on https://www.iscvms.com/	Medium	Accepted	Pass
6	X-Content-Type-Options Header Missing	Low	GET /vendor/lucide.min.js	Medium	Accepted	Pass

7	Authentication Request Identified	Informational	POST /login	High	N/A	Pass
8	Information Disclosure - Suspicious Comments	Informational	GET /admin	Medium	N/A	Pass
9	Modern Web Application	Informational	GET /admin	Medium	N/A	Pass
10	Session Management Response Identified	Informational	GET https://www.iscvms.com/	Medium	N/A	Pass
11	User Agent Fuzzer	Informational	GET /vendor/	Medium	N/A	Pass
12	User Controllable HTML Element Attribute (Potential XSS)	Informational	GET /admin/registrations?status=All	Low	Accepted	Pass

Rows 1 through 6 are missing headers and one public JavaScript file. The cookie in row 5 is the CSRF cookie, which the page is meant to read. Rows 7 through 11 are scanner notes, not a broken feature. No script execution, data leak, or account bypass was observed while using the site.

Part E — Summary for Chapter 4

Item	Result
Total manual security cases	18
Manual Passed / Failed	Passed 18 / Failed 0
ZAP setup and scan checklist	Passed 10 / Failed 0
ZAP High alerts	0
ZAP Medium alerts in the log	2
ZAP Low / Informational alerts in the log	10 (Low 4, Informational 6)
Critical issues fixed before deployment	Yes. There was no High alert and no manual case failed.
Overall security readiness	Ready
Short conclusion	All 18 manual checks passed. ZAP found no High-risk issue on www.iscvms.com. The remaining alerts are headers and scanner notes, and the site still worked after the scan.

Part F — Open Comments

Which security controls worked correctly?

Login rejected a wrong password and a locked account. Admin, Guard, and Student/Staff accounts opened only their own portals. A student could not open Admin pages, Admin documents, or another user's violations. Logout blocked the Back button. The RFID API and the AI parking API each returned 401 when called with no token. A denied visitor tap and a successful entry both appeared in Access Logs.

Which ZAP findings were most important, and how were they handled?

There were no High alerts. The two Medium findings are a missing Content-Security-Policy header on the home page and a cross-domain header on /vendor/lucide.min.js. They were accepted. They did not let a tester bypass a login, open another role's pages, or read another user's records. Alerts from other websites in the same ZAP session were not counted as ISCVMS findings.

Recommendations before deployment

The tested controls are working and the system is ready for pilot use. On a later pass, add Content-Security-Policy, Strict-Transport-Security, and X-Content-Type-Options, then scan only www.iscvms.com so the proxy does not record other sites. Those header items are improvements. They are not open failures in this test.

Acknowledgment

OWASP ZAP 2.17.0 and the manual security tests were performed on https://www.iscvms.com. The results above match the checks that were completed and the alerts saved in ISCVMS-ZAP-Report.html. Every case in this questionnaire passed.

Tester / Evaluator: Adrian Adams M. Daduya

Date: 18 October 2026

Signature: _____